

Date of Publication
December 5, 2022



WEEKLY **THREAT DIGEST**

Actors, Attacks, and Vulnerabilities

28 NOVEMBER to 4 DECEMBER 2022

Summary



Threat Actors

Hive Pro discovered three Actors that have been active in the last week. First [FIN7](#), a Russian threat actor group popular for financial crime. Second [ScarCruft](#), a North Korean threat actor group popular for Information theft and espionage. Third [UNC4191](#), an unknown threat actor group popular for espionage. For further details, see the key takeaway section for Actors.



Attacks

We also discovered five new malware strains that have been active over the last week. A new strain of [Punisher](#) ransomware is circulating via phishing sites and imposes a USD 1,000 bitcoin ransom to recover files. Malicious actors leveraged the Windows IKE flaw (CVE-2022-34721) to strike parts of Asia, Europe, and the United States in the [Bleed You](#) campaign. [Dolphin](#) backdoor exploited the (CVE-2020-1380) Memory Corruption Bug to infiltrate enterprises across Asia. Three new malware families [MISTCLOAK](#), [DARKDEW](#), and [BLUEHAZE](#), were deployed to execute espionage operations. [DuckLogs](#) is a new strain of information-stealing malware that has C&C servers in the wild. For further details, see the key takeaway section for Attacks.



Vulnerabilities

We discovered thirteen Vulnerabilities last week that organizations should Prioritize. Among these 13, there were two zero-day, and [ten](#) vulnerabilities that were addressed by google in Chrome 108. For further details, see the key takeaway section for Vulnerabilities.

*for detailed insights on each of the actors, attacks, vulnerabilities, targeted locations, and sectors click on the highlighted phrase.

Key Takeaways



Threat Actors

FIN7 (“Bleed You” campaign)

The FIN7 threat actor used the severe RCE (CVE-2022-34721) Windows Internet Key Exchange (IKE) vulnerability to support further malware and ransomware attacks.

ScarCruft (Dolphin)

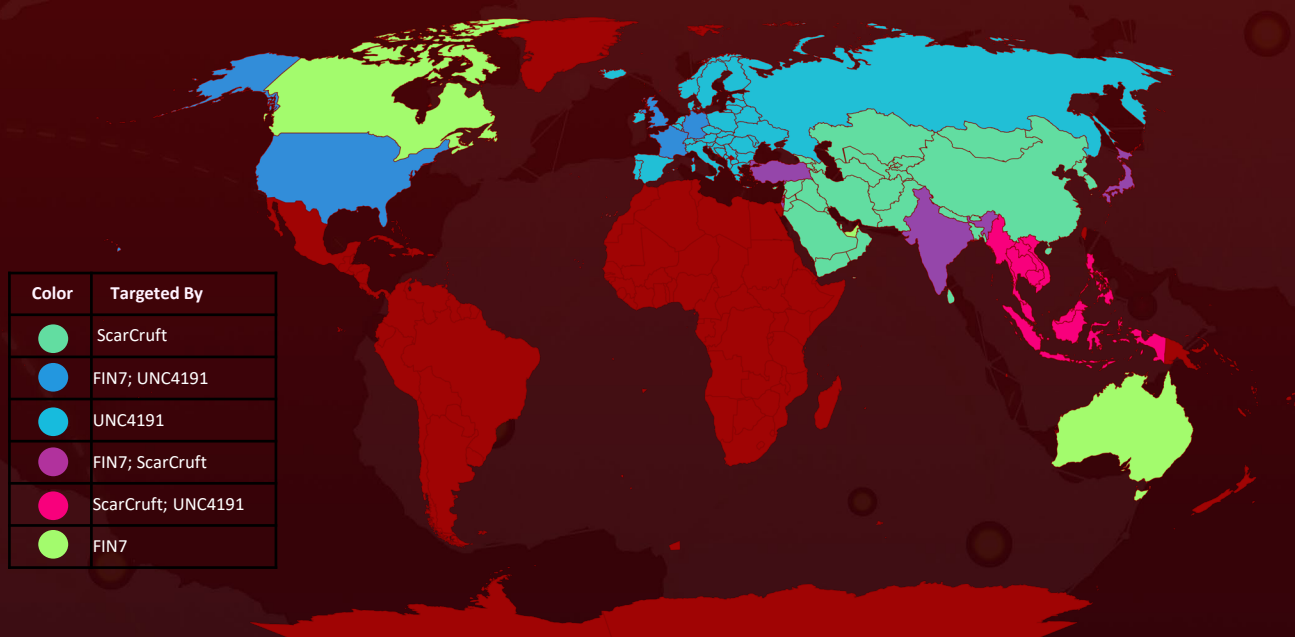
ScarCruft APT exploited Government and Military Organizations across Asia using the Dolphin backdoor and the CVE-2020-1380 RCE bug.

UNC4191 (MISTCLOAK, DARKDEW, and BLUEHAZE)

UNC4191, a suspected China-affiliated group, has been linked to several espionage attacks, especially in Southeast Asia.



Actor Map



Powered by Bing
© Australian Bureau of Statistics, GeoNames, Microsoft, Navinfo, OpenStreetMap, TomTom

*for detailed insights on each of the actors, attacks, vulnerabilities, targeted locations, and sectors click on the highlighted phrase.

Key Takeaways

Actor Details

ICON	NAME	ORIGIN	MOTIVE
	FIN7 (Gold Niagara, Calcium, Navigator, ATK 32, APT-C-11, ITG14, TAG-CR1, Carbon Spider)	Russia	Financial crime
	ScarCruft(Reaper, TEMP.Reaper, APT 37, Ricochet Chollima, Thallium, Group 123,Red Eyes,Geumseong121,Venus 121,Hermit,InkySquid,ATK 4,ITG10)	North Korea	Information theft and espionage
	UNC4191	Unknown	Information theft and espionage

*for detailed insights on each of the actors, attacks, vulnerabilities, targeted locations, and sectors click on the highlighted phrase.

Key Takeaways

Attacks

Punisher ransomware (unattributed)

A novel iteration of the Punisher ransomware is propagating as malware disguised as a COVID tracking application. Punisher Encryptor is a Windows-only .NET binary and used a timestamping technique to remain obscure.

Bleed You campaign (FIN7)

An ongoing BleedYou campaign is exploiting a severe RCE (CVE-2022-34721) flaw in Windows Internet Key Exchange (IKE) Protocol Extensions to aid further malware and ransomware attacks and lateral movement across affected networks.

Dolphin (ScarCraft)

The Dolphin backdoor first surfaced in April 2021, with spying capabilities and the ability to steal browser credentials. During the attack chain, it exploited the CVE-2020-1380 RCE flaw and leverages cloud storage services for C&C communication in subsequent versions.

MISTCLOAK, DARKDEW, and BLUEHAZE (UNC4191)

A string of espionage operations primarily in Southeast Asia that utilizes USB sticks as an initial infection vector and then employ three novel malware families, MISTCLOAK, DARKDEW, and BLUEHAZE, to gain and maintain access to the entity's network to collect intelligence.

DuckLogs (unattributed)

DuckLogs is a new information-stealing malware strain that is offered as part of the "Malware-as-a-Service" (MaaS) model. It steals and exfiltrates data from compromised devices.

TOP MITRE ATT&CK TTPS:

T1082

System
Information
Discovery

T1204

User Execution

T1059

Command and
Scripting
Interpreter

T1055

Process
Injection

T1562

Impair
Defenses

*for detailed insights on each of the actors, attacks, vulnerabilities, targeted locations, and sectors click on the highlighted phrase.

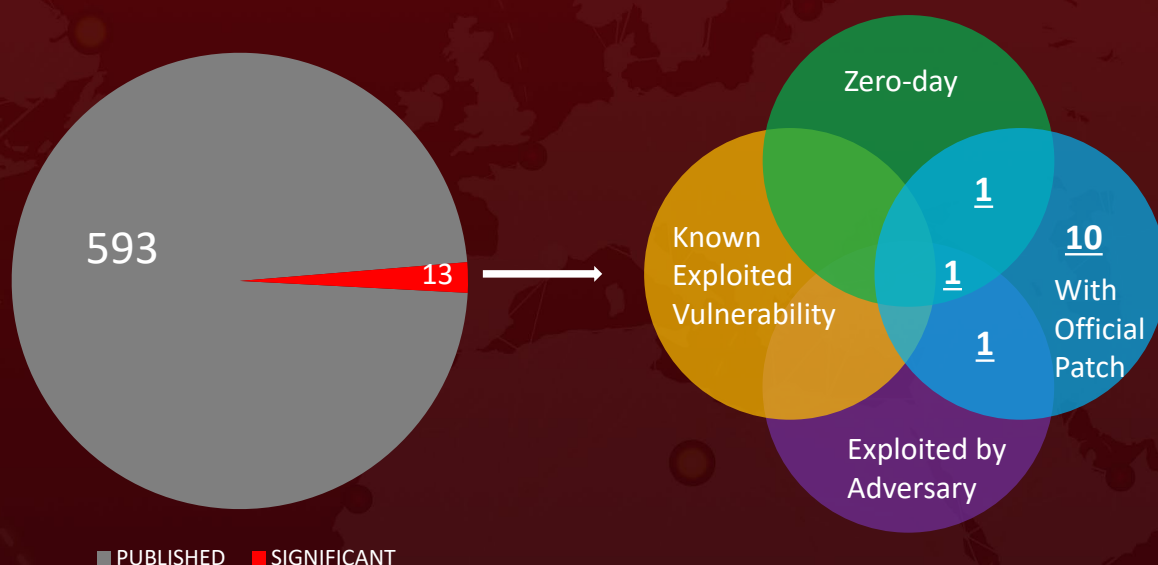
Key Takeaways



Vulnerabilities

Two Zero-Days & 11 Notable Mentions

One of the two zero-days, [CVE-2022-4135](#), is a regularly exploited Chrome bug that results in RCE. The other zero-day, CVE-2020-1380, was utilized by the [ScarCruft](#) APT to access target systems. The Windows IKE Protocol Extensions Remote Code Execution flaw (CVE-2022-34721) was exploited by [FIN7](#) and an unknown Chinese threat actor in the “Bleed You” campaign. With [Chrome 108](#), Google addressed a total of ten vulnerabilities.



*for detailed insights on each of the actors, attacks, vulnerabilities, targeted locations, and sectors click on the highlighted phrase.

Recommendations

Security Teams

This digest can be utilized as a drive to force security teams to prioritize the **13 significant vulnerabilities** and block the indicators related to the threat actor **FIN7, ScarCruft, UNC4191** and malware, **Punisher ransomware, Dolphin, MISTCLOAK, DARKDEW, and BLUEHAZE** and **DuckLogs**.

Uni5 Users

This is an actionable threat digest for HivePro Uni5 customers and they can get comprehensive insights into their threat exposure and can action it effortlessly over the HivePro Uni5 dashboard by

- Running a Scan to discover the assets impacted by the **13 significant vulnerabilities**
- Testing the efficacy of their security controls by simulating the attacks related to and malware **Punisher ransomware, Dolphin, MISTCLOAK, DARKDEW, and BLUEHAZE** and **DuckLogs** in Breach and Attack Simulation(BAS)



Threat Advisories

Check out the links below for more extensive remediation and security precautions

[Actively Exploited Zero-Day Bug in Chrome](#)

[A new strain of Punisher ransomware](#)

[Adversaries strike critical Windows IKE flaw in the “Bleed You” campaign](#)

[How ScarCruft APT group enhances its toolkit with a powerful Dolphin backdoor](#)

[Chinese cyber espionage hackers target Southeast Asian firms](#)

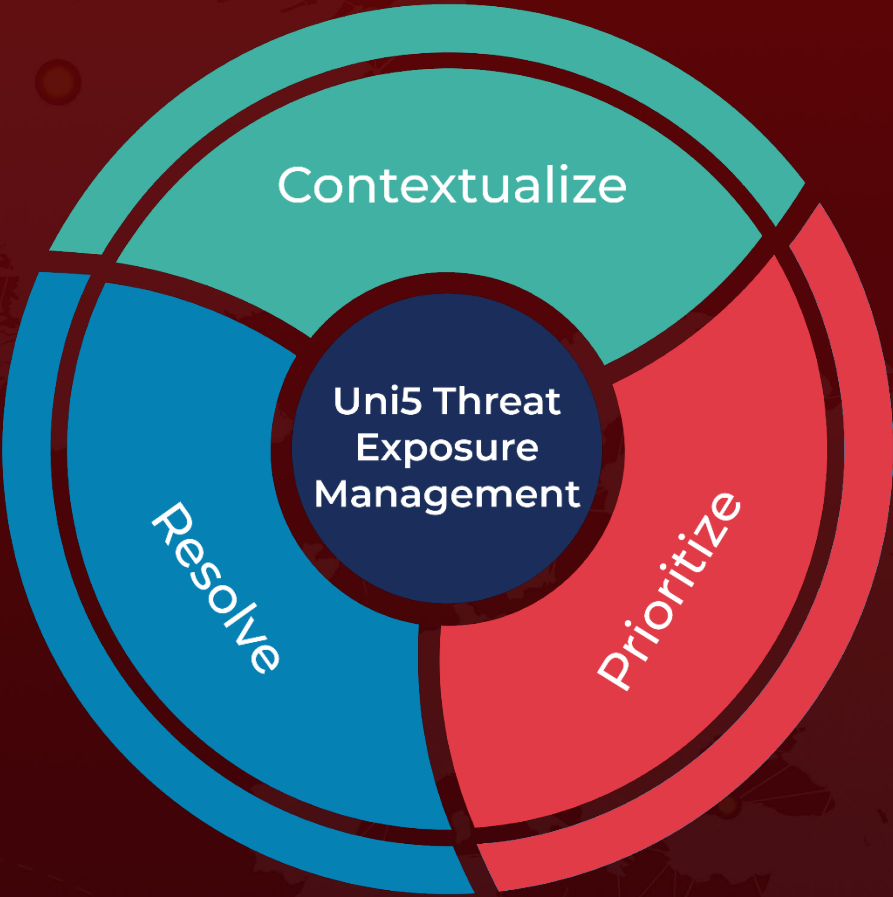
[Google addressed an array of bugs with Chrome 108](#)

[Do you know about an emerging new infostealer malware named DockLogs?](#)

What Next?

At HivePro, it is our mission to detect the most likely threats to your organization and to help you prevent them from happening.

Book a free demo with Hive Pro Uni5:Threat Exposure Management Platform.



REPORT GENERATED ON
December 5, 2022 • 3:55 AM

